

PROJEKTDOKUMENTATION

# CRA-Copilot

---

Ein Compliance-Werkzeug zum EU Cyber Resilience Act  
(Verordnung (EU) 2024/2847) für deutsche KMU — von der  
Betroffenheitsanalyse bis zur Behördenmeldung.

Stand: 14. Juni 2026 · Fassung 1.1

Inhalt: Anforderungen & Referenzen · Workflow · Mehrwert des Vorgehens

Hinweis: Dieses Dokument ist eine technische Projektdokumentation und keine Rechtsberatung. Alle regulatorischen  
Verweise sind vor Produktiveinsatz juristisch zu prüfen.

# 1. Überblick

Der **Cyber Resilience Act** (CRA, Verordnung (EU) 2024/2847) verpflichtet Hersteller, Importeure und Händler von „Produkten mit digitalen Elementen“, über den gesamten Produktlebenszyklus für Cybersicherheit zu sorgen — von der sicheren Entwicklung über ein Schwachstellenmanagement bis zu Melde- und Dokumentationspflichten. Für kleine und mittlere Unternehmen (KMU) ist die Umsetzung ohne Werkzeugunterstützung aufwändig und fehleranfällig.

**CRA-Copilot** begleitet diesen Weg in vier aufeinander aufbauenden Stufen mit *einem* Domänenmodell und *einer* Regelbasis. Es übersetzt die regulatorischen Pflichten in ein geführtes, evidenzbasiertes Verfahren und liefert am Ende belastbare Artefakte: Klassifizierung, Pflichtenkatalog, technische Dokumentation, SBOM-Überwachung und vorbereitete Behördenmeldungen.

**Grundhaltung des Werkzeugs.** Das System *strukturiert und formuliert, es bewertet aber nicht automatisch*. Jede sicherheits- oder meldungsrelevante Entscheidung trägt einen menschlichen Urheber. Regulatorische Verweise werden als versionierte Daten gepflegt — juristische Korrekturen sind ohne Software-Änderung möglich.

# 2. Anforderungen aus dem CRA und ihre Umsetzung

Die folgende Tabelle ordnet die wesentlichen CRA-Pflichten den Funktionen des Werkzeugs zu. Die Spalte „Referenz“ verweist auf die einschlägige Stelle in der Verordnung bzw. auf weiterführende Normen/Quellen (vollständige Linkliste in Abschnitt 5).

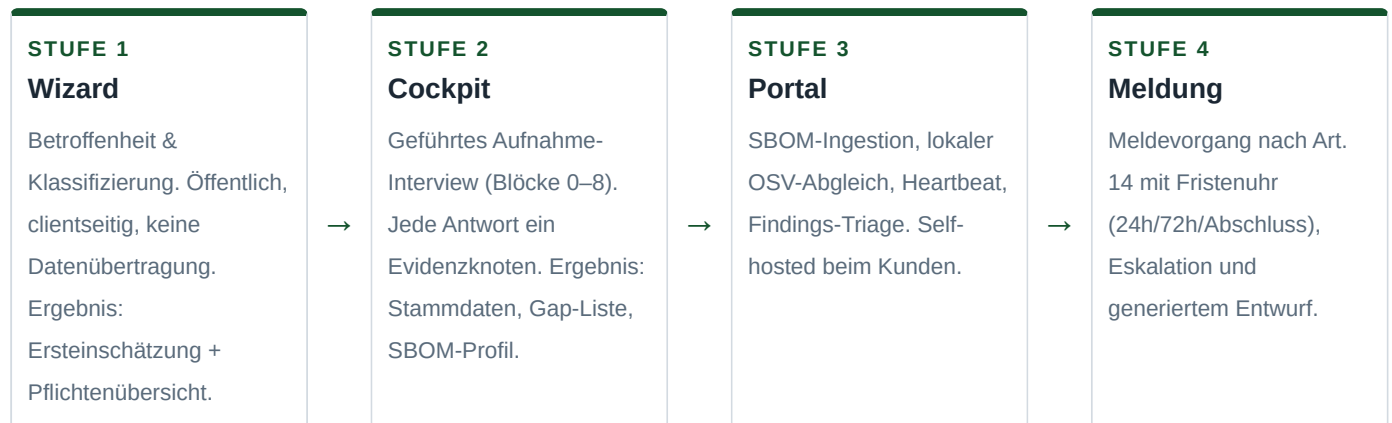
| Anforderung (CRA)                     | Umsetzung im CRA-Copilot                                                                                                                                                               | Referenz                                      |
|---------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------|
| Anwendungsbereich & Rolle bestimmen   | Öffentlicher Betroffenheits-Wizard ermittelt Rolle, Produktart, EU-Inverkehrbringen und Ausnahmereiche; rein clientseitig, keine Datenübertragung.                                     | Art. 2 (Anwendungsbereich), Art. 3 (Begriffe) |
| Klassifizierung (wichtig/kritisch)    | Regel-Engine schlägt die Kategorie (Standard / wichtig Klasse I/II / kritisch) aus den Produktangaben vor; im Aufnahme-Cockpit bestätigt oder mit Begründung überschrieben.            | Anhang III, Anhang IV; DVO (EU) 2025/2392     |
| Grundlegende Sicherheitsanforderungen | Strukturierte Erhebung des Erfüllungsgrads je Anforderung (sichere Defaults, Zugriffskontrolle, Update-Mechanismus ...); jede Lücke erzeugt einen priorisierten Eintrag der Gap-Liste. | Anhang I Teil I                               |
| Schwachstellenmanagement & SBOM       | Erfassung des Prozesses; Portal nimmt SBOMs (CycloneDX/SPDX) entgegen und gleicht sie kontinuierlich gegen einen lokalen OSV-Spiegel ab (Findings + Triage).                           | Anhang I Teil II; BSI TR-03183-2; OSV         |

| Anforderung (CRA)                                 | Umsetzung im CRA-Copilot                                                                                                                                                                                                                            | Referenz                                  |
|---------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------|
| <b>Meldepflichten</b><br>(24h/72h/Abschluss)      | Meldevorgang aus einem als „aktiv ausgenutzt“ eingestuften Finding oder als freie Vorfallmeldung; Fristenuhr, Eskalation und generierter Melde-Entwurf zum manuellen Absenden — inklusive des Kopf-Hashes der Nachweis-Kette als Integritäts-Anker. | Art. 14 (Meldung), Art. 16 (Plattform)    |
| <b>Nutzerbenachrichtigung</b>                     | Generierter Entwurf zur Information betroffener Nutzer über Vorfall und Abhilfemaßnahmen; Versand unveränderlich festgehalten.                                                                                                                      | Art. 14 Abs. 8                            |
| <b>Meldekontakt</b> (security.txt)                | Erzeugung einer security.txt (RFC 9116) aus der erfassten Kontaktstelle; Bereitstellung unter /.well-known/ ; jede Veröffentlichung als verketteter Beleg.                                                                                          | Art. 13 Abs. 6                            |
| <b>Nachweisführung</b><br>(Manipulationsevidenz)  | Append-only Datensätze (Evidenz, Lieferungen, Meldungen) in einer kryptografischen Hash-Kette; Verifikation erkennt nachträgliche Änderungen. Optionales freiwilliges BSI-Erstanschreiben verankert den Stand extern.                               | Art. 13 Abs. 14 (Aufbewahrung)            |
| <b>Support-Zeitraum</b> festlegen & kommunizieren | Verbindliche Festlegung des Unterstützungszeitraums mit Begründung; kundensichtbare Support-Zeitraum-Erklärung als Artefakt.                                                                                                                        | Art. 13 Abs. 8                            |
| <b>Technische Dokumentation</b><br>& CE           | Gap-Analyse gegen die Anhang-VII-Gliederung; Markierung, was vorhanden, generierbar oder zu liefern ist; Vorbereitung der Konformitätserklärung.                                                                                                    | Art. 31, Anhang VII; Art. 28/30, Anhang V |
| <b>Benutzerinformationen</b>                      | Prüfung, ob Kontaktstelle, Support-Zeitraum und Update-Anleitung in Produkt/Doku integriert sind.                                                                                                                                                   | Anhang II                                 |

**Geltungstermine.** Die Meldepflichten gelten ab dem 11. September 2026, die vollständige Anwendung des CRA ab dem 11. Dezember 2027 (Art. 71). Das Werkzeug ordnet jeder Pflicht den passenden Zeithorizont zu.

### 3. Workflow — die vier Stufen

CRA-Copilot bildet den Compliance-Weg als durchgängige Kette ab. Alle vier Oberflächen greifen auf *dasselbe* Backend und *dieselbe* Regelbasis zu — es gibt keine doppelte Methodik.



#### Stufe 1 — Betroffenheits-Wizard

Ein anonymer Selbsttest beantwortet die erste Frage jedes Anbieters: „Betrifft mich der CRA, und wie?“ Der Wizard läuft vollständig im Browser — als Produktversprechen, technisch durch einen Test abgesichert, der jeden ausgehenden Netzwerk-Aufruf unterbindet. Ergebnis ist eine Kategorie mit Begründungspfad, ein Pflichtenkatalog mit Fristen und eine druckbare Ersteinschätzung.

#### Stufe 2 — Aufnahme-Cockpit

Im moderierten Workshop wird das Produkt entlang von neun Themenblöcken (Mandant & Rollen, Produktabgrenzung, Klassifizierung, Risikokontext, Schwachstellenmanagement, Support, Lieferkette, SBOM-Profil, Dokumentation) strukturiert erfasst. Kernprinzipien:

- **Evidenz statt Freitext:** Jede Aussage wird als unveränderlicher Evidenzknoten mit Quelle (Person, Datum, Gesprächsleiter) persistiert; Korrekturen erzeugen neue Knoten, der Verlauf bleibt lückenlos.
- **Lücken sind First-Class:** „unbekannt“ und „existiert nicht“ sind gültige, getrennte Antworten; jede Lücke wird zur priorisierten Hausaufgabe mit Annex-Bezug.
- **Klassifizierungsvorschlag:** Dieselbe Regel-Engine wie im Wizard schlägt die Kategorie vor; der Gesprächsleiter bestätigt oder überschreibt sie mit dokumentierter Begründung.

#### Stufe 3 — Kundenportal (Monitoring)

Das Portal wird **beim Kunden betrieben** (self-hosted) und nimmt die SBOMs aus der CI entgegen. Die Software-Stückliste wird kontinuierlich gegen einen **lokal gespiegelten** Stand der Open-Source-Schwachstellendatenbank OSV abgeglichen — die Komponentenliste verlässt das System nicht. Zwei Takte sind bewusst getrennt: die SBOM-Erneuerung ist *ereignisgetrieben* (Produktänderung), die Schwachstellen-Neubewertung läuft *kontinuierlich* gegen das unveränderte SBOM. Ein „Heartbeat“ überwacht nur die Lieferdisziplin, nicht die CVE-Aktualität.

#### Stufe 4 — Meldeworkflow (Art. 14)

Wird ein Finding durch einen Menschen als „aktiv ausgenutzt“ eingestuft — oder ein Vorfall ohne zugeordnete Schwachstelle gemeldet — eröffnet das Portal einen Meldevorgang mit drei Stufen und abgeleiteten Fristen: **Frühwarnung binnen 24 Stunden, Meldung binnen 72 Stunden** und Abschlussbericht (14 Tage bei aktiv ausgenutzter Schwachstelle bzw. ein Monat bei schwerwiegendem Vorfall). Das System erzeugt je Stufe einen

strukturierten Entwurf; das Absenden über die offizielle ENISA/CSIRT-Plattform bleibt ein bewusster, menschlicher Schritt. Eingereichte Stufen sind als Nachweis unveränderlich.

## 4. Mehrwert des Vorgehens

---

Der Nutzen entsteht weniger aus einzelnen Funktionen als aus durchgängig angewandten Konstruktionsprinzipien:

### 4.1 Regulatorik als Daten, nicht als Code

Artikel- und Annex-Verweise, Schwellenwerte und Fristen liegen in versionierten Datendateien mit Review-Status. Eine juristische Korrektur (z. B. eine angepasste Frist oder eine neue harmonisierte Norm) ist eine Datenänderung mit Freigabe-Vermerk — keine Software-Auslieferung. Das senkt die Pflegekosten und macht den fachlichen Review unabhängig vom Entwicklungszyklus.

### 4.2 Eine Methodik, vier Oberflächen

Wizard, Cockpit und Portal teilen sich Regel-Engine und Domänenmodell. Die Klassifizierung, die der Anbieter im Selbsttest sieht, ist dieselbe, die im Workshop verbindlich gemacht wird — keine widersprüchlichen Zweitlogiken, keine Methodik-Duplikation.

### 4.3 Beweisbarkeit durch Unveränderlichkeit und Hash-Verkettung

Evidenzknoten, SBOM-Lieferungen, eingereichte Meldungen, veröffentlichte security.txt und Behörden-Anschreiben sind append-only und auf Datenbankebene per Trigger gegen Änderung gesichert. Darüber liegt eine **kryptografische Hash-Kette**: Jeder dieser Datensätze wird beim Anlegen verkettet (SHA-256 über den Inhalt, verknüpft mit dem Vorgänger). Eine Verifikation rechnet die Kette nach und hasht jeden Datensatz erneut — damit werden *sowohl* nachträglich geänderte Zeilen *als auch* entfernte oder umsortierte Kettenglieder erkennbar, selbst wenn der Schutz-Trigger umgangen wurde. Das liefert Manipulationsevidenz, nicht nur -prävention.

Damit auch ein privilegierter Insider, der die gesamte Kette konsistent neu rechnet, auffällt, kann der aktuelle Kopf-Hash **extern verankert** werden: Er geht in jede Behördenmeldung ein und kann über ein freiwilliges BSI-Erstanschreiben (Meldebereitschaft) mit behördlicher Eingangsbestätigung zeitlich bezeugt werden. Für ein Compliance-Produkt ist diese lückenlose, nachweisbare Historie kein Beiwerk, sondern das Kernversprechen.

### 4.4 Datenhoheit über die gesamte Kette

Der Wizard überträgt nichts, das Cockpit läuft lokal, das Portal wird beim Kunden betrieben, und der Schwachstellenabgleich erfolgt gegen einen lokalen OSV-Spiegel. Sensible Architekturinformationen (die Abhängigkeitsliste eines Produkts) verlassen die Kundeninfrastruktur nicht. Die einzige bewusste Ausnahme ist die menschlich ausgelöste Meldung an die Behörde.

### 4.5 Mensch entscheidet, Maschine strukturiert

Das System bewertet keine Risiken automatisch und meldet nichts von selbst. Die Schwelle „aktiv ausgenutzt“ etwa ist eine bewusste Tatsachenfeststellung mit Urheber — eine Fehlmeldung an die Behörde hat reale Folgen. Diese Trennung schützt vor Automatisierungs-Fehlern und hält die Verantwortung dort, wo sie hingehört.

### 4.6 Qualität ist nachgewiesen

Die fachliche Logik ist durch tabellengetriebene Fallkataloge und Eigenschafts-Tests abgesichert, die Persistenz gegen eine echte PostgreSQL-Datenbank, die Oberflächen durch schlanke End-to-End-Tests inklusive der „keine-Datenübertragung“-Zusicherung. Jede Änderung läuft nur bei grünem Teststand in die Hauptlinie.

**Zusammengefasst:** CRA-Copilot verwandelt einen unübersichtlichen, juristisch getriebenen Pflichtenkatalog in einen geführten, nachweisbaren und datensouveränen Prozess — vom ersten „Betrifft mich das?“ bis zur fristgerechten Behördenmeldung, mit dem Menschen an jeder bewertenden Stelle.

## 5. Online-Referenzen

---

### Verordnung & Durchführung

- Verordnung (EU) 2024/2847 (Cyber Resilience Act), konsolidierter Text — EUR-Lex: [eur-lex.europa.eu/legal-content/DE/TXT/?uri=OJ:L\\_202402847](https://eur-lex.europa.eu/legal-content/DE/TXT/?uri=OJ:L_202402847)
- Durchführungsverordnung (EU) 2025/2392 (technische Beschreibungen der Produktkategorien nach Anhang III/IV): [eur-lex.europa.eu/legal-content/DE/TXT/?uri=OJ:L\\_202502392](https://eur-lex.europa.eu/legal-content/DE/TXT/?uri=OJ:L_202502392)
- Europäische Kommission — „Shaping Europe's digital future“, CRA-Überblick: [digital-strategy.ec.europa.eu/en/policies/cyber-resilience-act](https://digital-strategy.ec.europa.eu/en/policies/cyber-resilience-act)

### Einzelne Pflichten (Artikel/Anhänge)

- Art. 2 Anwendungsbereich · Art. 3 Begriffsbestimmungen
- Art. 13 Pflichten der Hersteller (Abs. 8: Support-Zeitraum)
- Art. 13 Abs. 6 Meldekontakt (security.txt) · Abs. 8 Support-Zeitraum · Abs. 14 Aufbewahrung
- Art. 14 Meldepflichten (24h/72h/Abschluss) · Abs. 8 Nutzerinformation · Art. 16 einheitliche Meldeplattform
- Art. 28/30 CE-Kennzeichnung & EU-Konformitätserklärung (Anhang V)
- Art. 31, Anhang VII technische Dokumentation
- Art. 71 Zeitpunkt der Anwendung (Meldepflichten 09/2026, volle Anwendung 12/2027)
- Anhang I Teil I grundlegende Anforderungen · Teil II Schwachstellenmanagement
- Anhang II Benutzerinformationen · Anhang III/IV Produktkategorien

### Normen, Datenquellen & Formate

- BSI TR-03183-2 „Software Bill of Materials (SBOM)“: [bsi.bund.de](https://bsi.bund.de) — TR-03183
- ENISA (Agentur der EU für Cybersicherheit): [enisa.europa.eu](https://enisa.europa.eu)
- OSV — Open Source Vulnerabilities (Schwachstellendatenbank & Schema): [osv.dev](https://osv.dev)
- CycloneDX (SBOM-Standard): [cyclonedx.org](https://cyclonedx.org) · SPDX: [spdx.dev](https://spdx.dev)
- RFC 9116 (security.txt): [rfc-editor.org/rfc/rfc9116](https://rfc-editor.org/rfc/rfc9116)

**Rechtlicher Hinweis.** Diese Dokumentation dient der technischen Erläuterung des Werkzeugs CRA-Copilot. Sie ersetzt keine Rechtsberatung. Sämtliche Artikel- und Anhang-Verweise sowie Fristen sind vor einem Produktiveinsatz juristisch zu prüfen; im Werkzeug sind regulatorische Inhalte entsprechend als prüfpflichtig markiert.